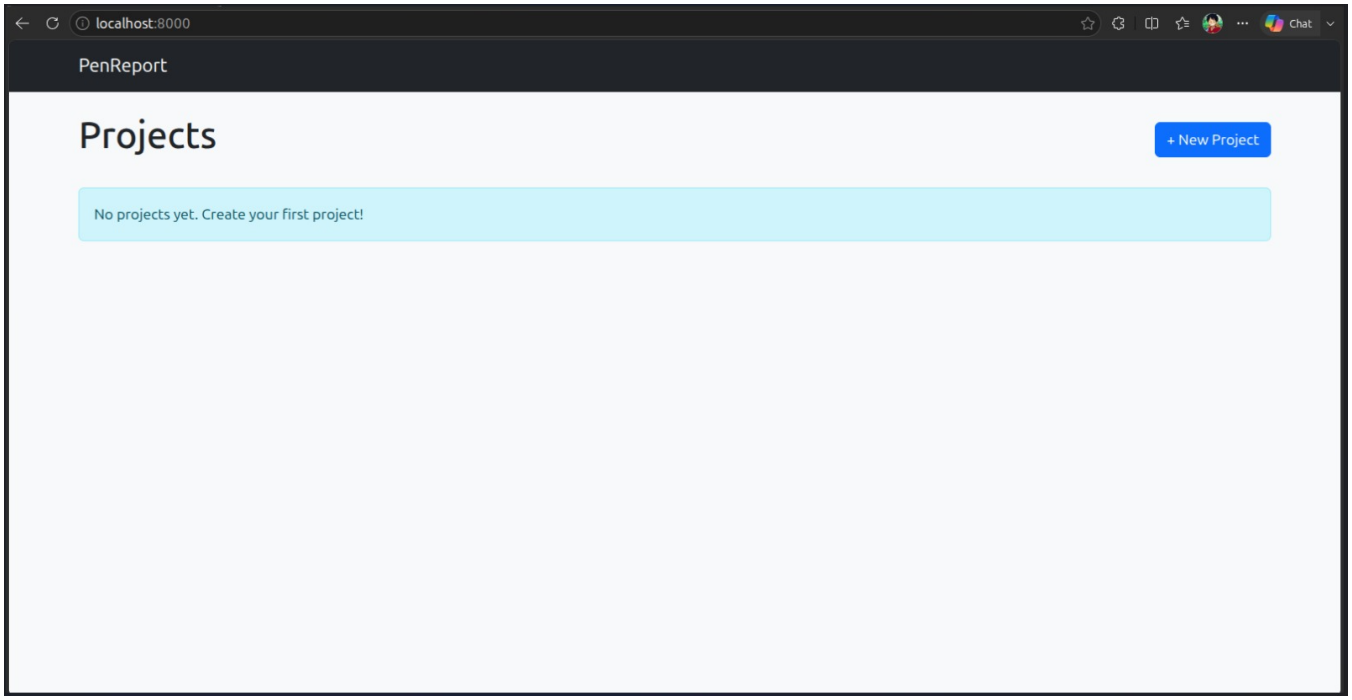
PenReport Outputs

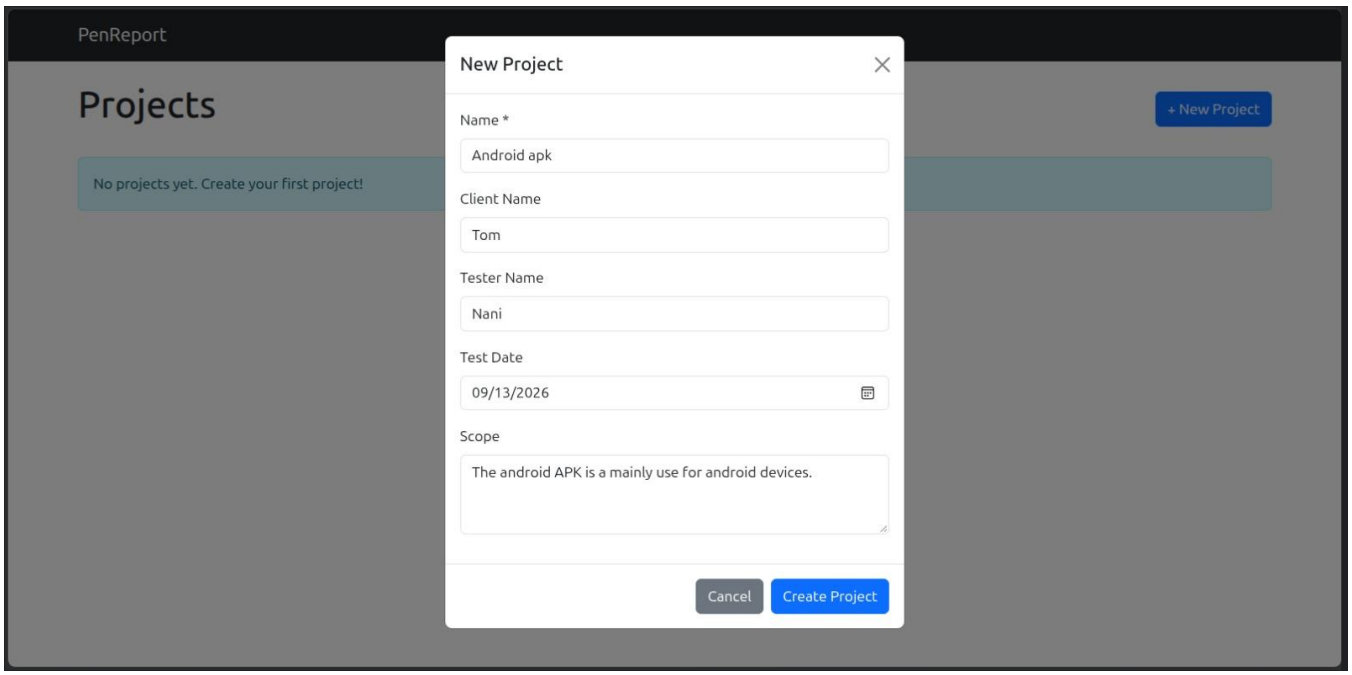
Step 1: Open PenReport

The Projects page appears with no projects created yet. Select “+ New Project” to begin.



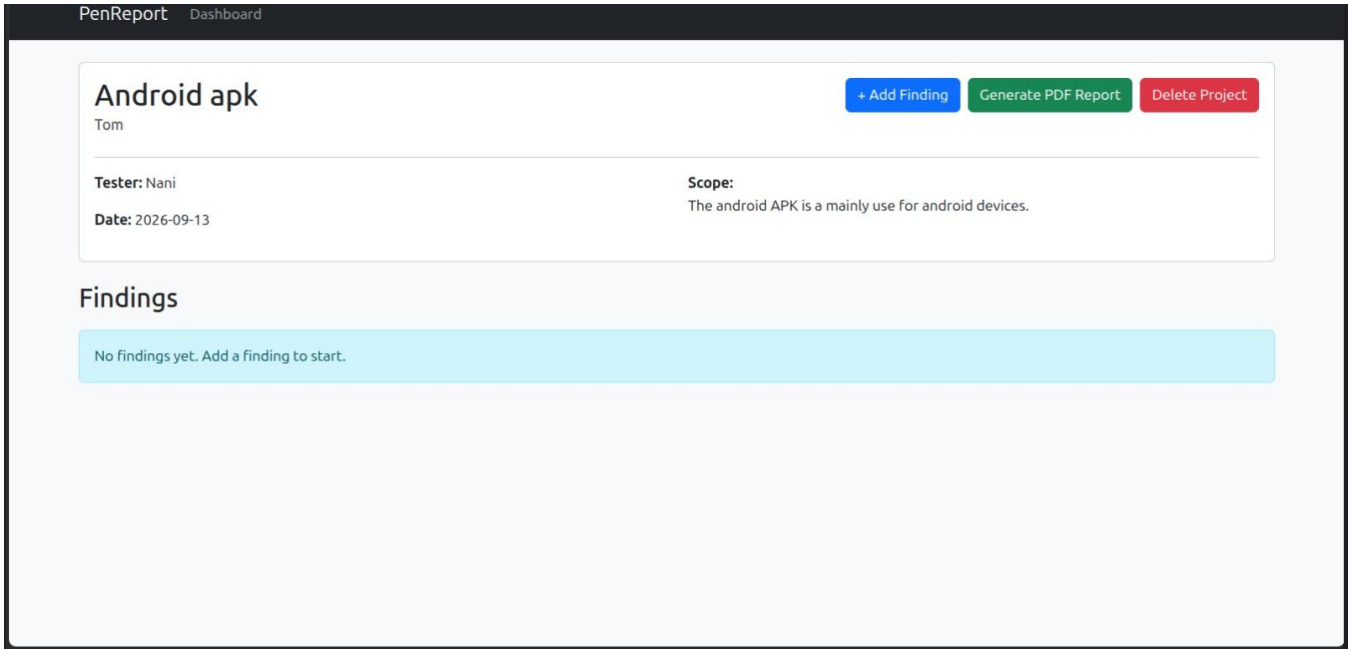
Step 2: Create a new project

Enter the project name, client name, tester name, test date, and scope, then select “Create Project”.



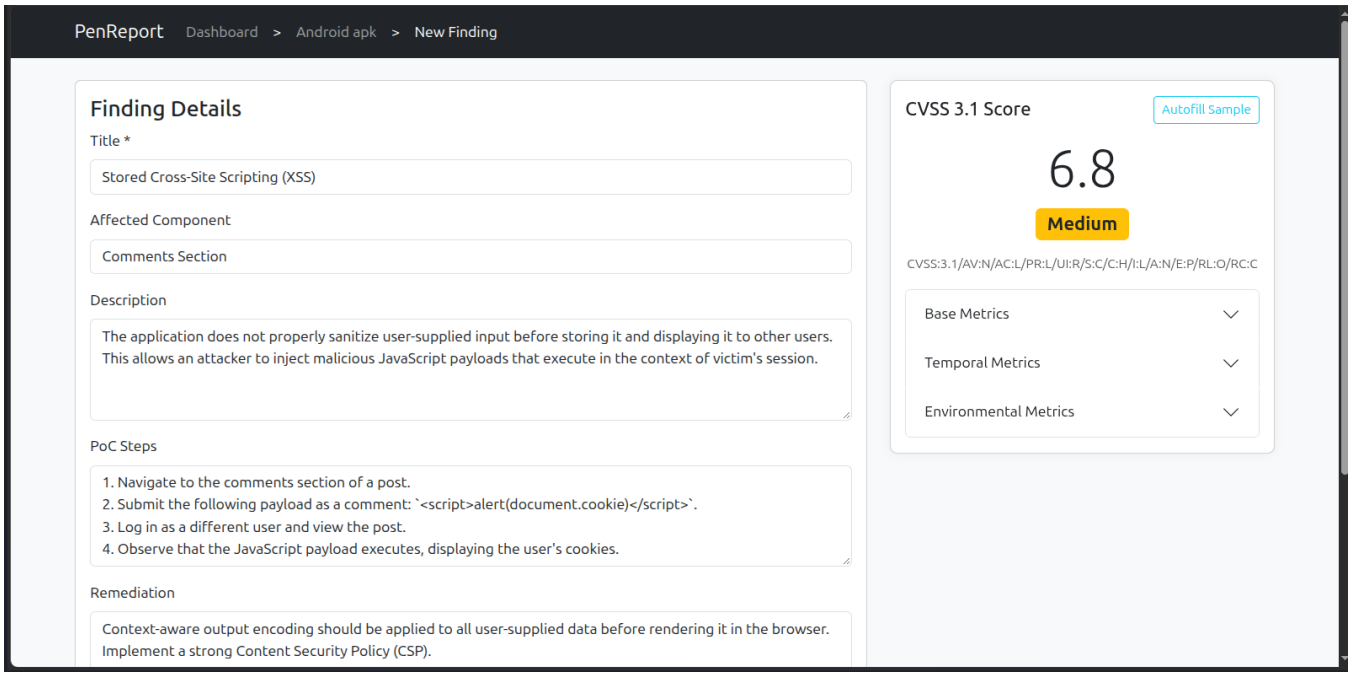
Step 3: View project details

The project dashboard displays project information and options to add findings, generate a PDF report, or delete the project.



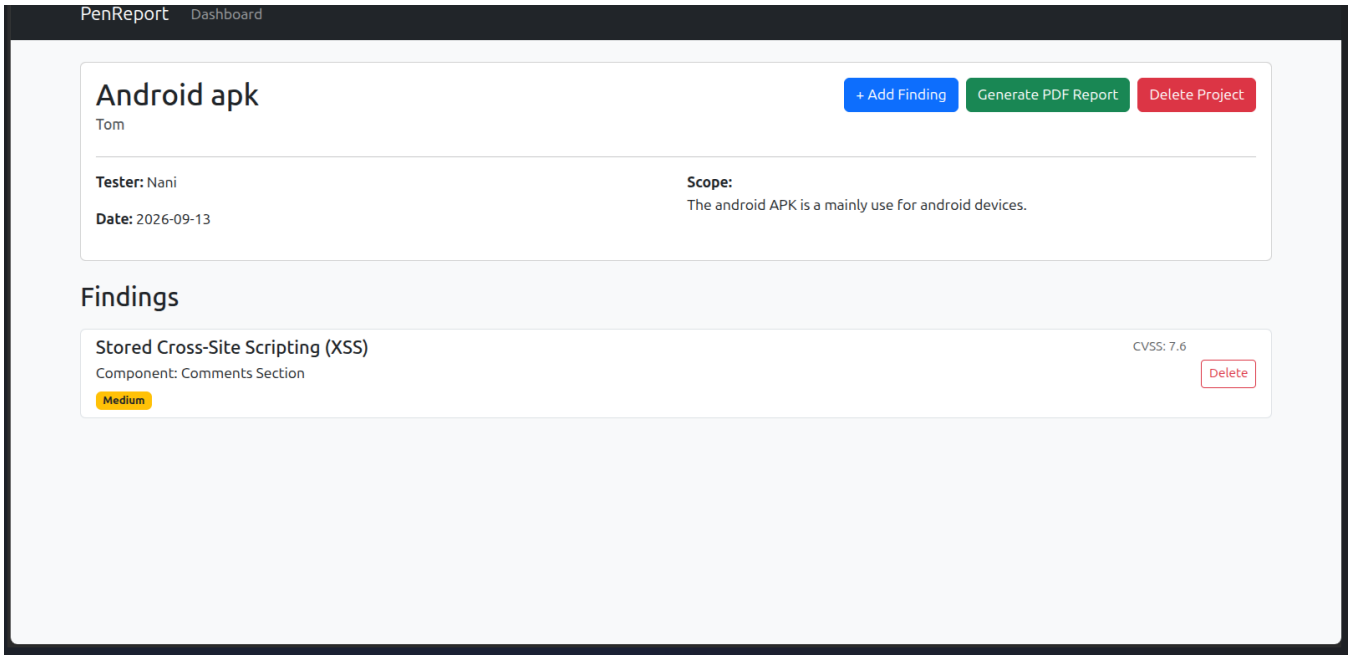
Step 4: Add a finding

Enter the finding details, proof-of-concept steps, remediation, evidence, and CVSS 3.1 metrics.



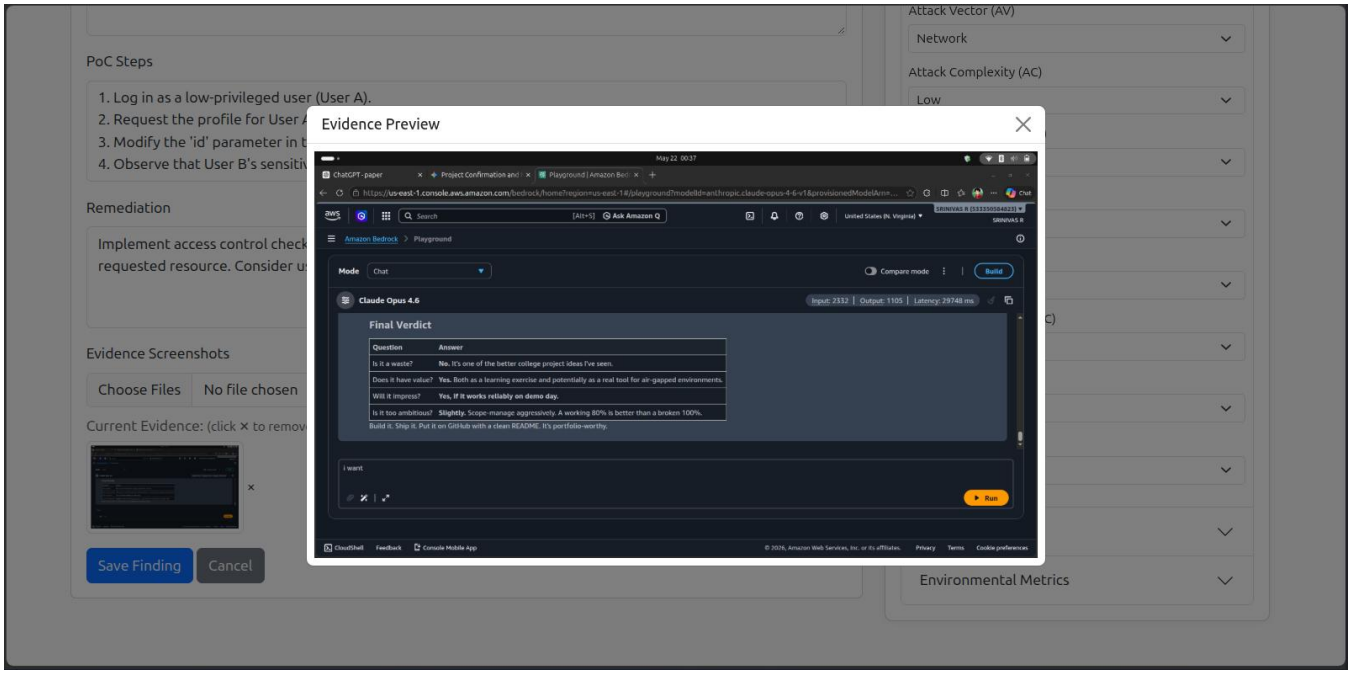
Step 5: Review of the saved findings

The project page displays the saved finding with its component, severity, and CVSS score.



Step 6: Preview evidence

The evidence preview displays the screenshot attached to the finding. Close the preview and save the findings when finished.



Original Report

PENETRATION TEST REPORT

Nani

Client: nani

Tester: asd

Date: 2026-09-12

CONFIDENTIAL

Executive Summary

This report documents the findings of the penetration test conducted for nani on the Nani project. The assessment identified a total of 2 findings. The breakdown by severity is as follows:

Severity	Count
Critical	1
High	1
Medium	0
Low	0
None	0

Findings Summary

#	Title	Severity	CVSS Score
1	SQL Injection	Critical	9.8
2	Insecure Direct Object Reference (IDOR)	High	8.1

1. SQL Injection Critical

Base Score	Temporal Score	Environmental Score	Overall Score
9.8	9.4	9.4	**9.8**

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:H/RL:O/RC:C

Description

The application is vulnerable to SQL injection due to improper sanitization of user input in the authentication endpoint. An attacker can manipulate SQL queries to bypass authentication, access unauthorized data, or execute arbitrary commands on the database server.

Affected Component

Login Endpoint (/api/login)

Proof of Concept Steps

1. Navigate to the login page.
2. Enter `' OR '1'='1` in the username field.
3. Enter any password and submit.
4. Observe that authentication is bypassed.

Remediation

Use parameterized queries or prepared statements for all database interactions. Validate and sanitize all user input before processing.

2. Insecure Direct Object Reference (IDOR) High

Base Score	Temporal Score	Environmental Score	Overall Score
8.1	7.4	7.4	**8.1**

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N/E:P/RL:W/RC:C

Description

The application uses easily guessable, sequential identifiers for sensitive resources (e.g., user profiles, invoices). It fails to verify if the requesting user has authorization to access the specific resource requested.

Affected Component

User Profile API (/api/users/{id})

Proof of Concept Steps

1. Log in as a low-privileged user (User A).
2. Request the profile for User A to observe the URL structure.
3. Modify the 'id' parameter in the URL to match the ID of another user (User B).
4. Observe that User B's sensitive information is successfully returned.

Remediation

Implement access control checks to verify that the currently authenticated user is authorized to access the requested resource. Consider using unpredictable UUIDs instead of sequential integers for object identifiers.

Appendix - CVSS Scoring Legend

The Common Vulnerability Scoring System (CVSS) is a free and open industry standard for assessing the severity of computer system security vulnerabilities.

Severity Level	Base Score Range
None	0.0
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0